

Marco normativo gestión responsable de la

Internet, Ómnibus digital, RGPD
/IEC

José Manuel Aroca Fernández

Material docente

Octubre de 2026

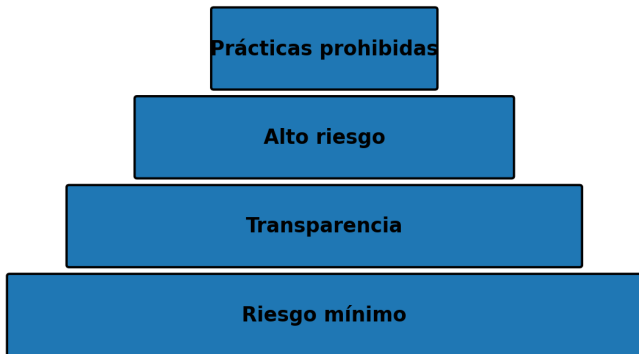
Cómo utilizar esta presentación

- Resumen esquemático para formación y discusión.
- Cada sección comienza con una cabecera normativa y un resumen general.
- Las diapositivas siguientes desarrollan conceptos, obligaciones y aplicación práctica.
- Contrastar siempre las obligaciones con los textos oficiales vigentes.

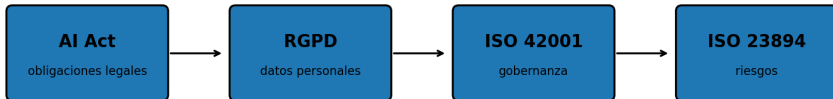
REGLAMENTO (UE) 2024

**Artificial
Intelligence Act
— AI Act**

Enfoque basado en riesgos del AI Act



Marco normativo europeo de la IA



Resumen de la norma

Idea central

El Reglamento (UE) 2024/1689 establece un marco jurídico armonizado para la inteligencia artificial en la Unión Europea. Su enfoque central es proporcional al riesgo: prohíbe determinadas prácticas, establece requisitos reforzados para sistemas de alto riesgo y fija obligaciones de transparencia para determinados sistemas. También regula aspectos específicos de los modelos de IA de uso general, la gobernanza, la supervisión y la vigilancia del mercado.

- **Naturaleza:** Reglamento de la Unión Europea.
- **Enfoque:** gobernanza, riesgos, impactos y cumplimiento según el marco aplicable.
- **Aplicación:** analizar siempre alcance, contexto, responsables y fecha de aplicación.

Objetivos de la sesión

- Comprender el marco europeo de IA y su enfoque basado en riesgos.
- Distinguir obligaciones legales de normas técnicas voluntarias.
- Relacionar AI Act, Ómnibus digital, RGPD e ISO.
- Traducir los requisitos a controles organizativos y evidencias.

Mapa normativo

- Reglamento (UE) 2024/1689: Ley de IA.
- Reglamento (UE) 2026/1744: modifica y simplifica partes de la Ley de IA.
- RGPD (UE) 2016/679: protección de datos personales.
- ISO/IEC 42001: sistema de gestión de IA.
- ISO/IEC 23894: gestión de riesgos de IA.
- ISO/IEC 42005: evaluación de impacto de sistemas de IA.

Norma jurídica frente a norma técnica

- Reglamentos UE: obligatorios y directamente aplicables en su ámbito.
- Normas ISO/IEC: estándares técnicos, normalmente voluntarios.
- Una norma ISO no sustituye el cumplimiento legal.
- La armonización y las referencias normativas pueden apoyar la demostración de conformidad.
- Verificar siempre la versión vigente y el ámbito de aplicación.

¿Qué es un sistema de IA?

- Sistema basado en máquina que infiere cómo generar salidas a partir de entradas.
- Las salidas pueden ser predicciones, contenidos, recomendaciones o decisiones.
- Puede influir en entornos físicos o virtuales.
- No todo software es necesariamente un sistema de IA a efectos del Reglamento.
- Analizar función, autonomía, adaptabilidad y contexto de uso.

Objetivos del AI Act

- Promover una IA centrada en las personas y fiable.
- Proteger salud, seguridad y derechos fundamentales.
- Armonizar reglas de comercialización, puesta en servicio y uso.
- Establecer obligaciones proporcionales al riesgo.
- Favorecer innovación y seguridad jurídica.

Ámbito territorial y material

- Afecta a actores y usos conectados con el mercado de la UE según los supuestos legales.
- Incluye proveedores, responsables del despliegue y otros operadores definidos.
- Puede alcanzar a proveedores establecidos fuera de la UE.
- Existen exclusiones y regímenes específicos: revisar artículos 2 y siguientes.
- El análisis debe hacerse caso por caso.

Actores principales

- Proveedor: desarrolla o encarga desarrollar y comercializa/implanta bajo su nombre.
- Responsable del despliegue: utiliza el sistema bajo su autoridad.
- Importador y distribuidor: funciones en la cadena de suministro.
- Representante autorizado: actúa por encargo cuando corresponda.
- Fabricante de producto y usuarios afectados pueden tener roles adicionales.

Ciclo de vida de cumplimiento

- Diseño y propósito previsto.
- Clasificación regulatoria y evaluación de riesgos.
- Datos, documentación, pruebas y validación.
- Conformidad, registro y transparencia cuando proceda.
- Despliegue, supervisión, incidentes y mejora continua.

Enfoque basado en riesgos

- Riesgo inaceptable: prácticas prohibidas.
- Alto riesgo: requisitos reforzados y evaluación de conformidad.
- Riesgo de transparencia: informar a las personas en supuestos definidos.
- Riesgo mínimo: sin obligaciones específicas comparables, pero siguen otras leyes.
- La categoría depende del uso previsto y de los criterios legales.

Prácticas prohibidas: idea general

- El artículo 5 prohíbe prácticas concretas de IA.
- La prohibición no equivale a prohibir toda tecnología relacionada.
- Importan el propósito, el contexto, las condiciones y las excepciones legales.
- Evaluar especialmente manipulación, vulnerabilidad y puntuación social.
- Consultar la redacción vigente y las excepciones aplicables.

Prácticas prohibidas: ejemplos

- Técnicas manipuladoras o engañosas con efectos dañinos en los supuestos legales.
- Explotación de vulnerabilidades por edad, discapacidad o situación social.
- Puntuación social con consecuencias prohibidas.
- Determinados usos de identificación biométrica remota en tiempo real por autoridades.
- Inferencia de emociones en trabajo y educación, salvo excepciones tasadas.
- La lista debe comprobarse contra el artículo 5 consolidado.

Identificación biométrica

- Distinguir verificación, identificación y categorización biométrica.
- El contexto y el actor son determinantes.
- Los usos policiales tienen reglas específicas y excepciones estrictas.
- La base jurídica y las garantías deben documentarse.
- No asumir que todo tratamiento biométrico tiene el mismo régimen.

Sistemas de alto riesgo

- Vías principales: producto regulado de seguridad y casos del anexo III.
- Ejemplos potenciales: empleo, educación, servicios esenciales y biometría.
- No basta con que el sistema sea técnicamente complejo.
- Analizar propósito previsto, función y excepciones del artículo 6.
- Registrar la justificación de clasificación.

Alto riesgo en productos

- Sistemas que son productos o componentes de seguridad sujetos a legislación sectorial.
- Puede exigirse evaluación de conformidad del producto.
- La Ley de IA se integra con las reglas sectoriales aplicables.
- El Ómnibus 2026 modifica aspectos del marco para determinados productos.
- Revisar artículo 6, anexos I y las modificaciones vigentes.

Alto riesgo: anexo III

- Biometría en los supuestos enumerados.
- Infraestructuras críticas.
- Educación y formación profesional.
- Empleo, gestión de trabajadores y acceso al autoempleo.
- Servicios esenciales, aplicación de la ley, migración y justicia.
- La inclusión depende del uso concreto y de las excepciones previstas.

Obligaciones del proveedor de alto riesgo

- Sistema de gestión de riesgos.
- Gobernanza y calidad de datos cuando proceda.
- Documentación técnica y registros automáticos.
- Instrucciones de uso y transparencia para el despliegue.
- Supervisión humana, precisión, robustez y ciberseguridad.
- Evaluación de conformidad, declaración y marcado cuando corresponda.

Gestión de riesgos durante el ciclo de vida

- Identificar peligros y daños previsibles.
- Estimar y evaluar riesgos conocidos y razonablemente previsibles.
- Adoptar medidas de mitigación y pruebas.
- Reevaluar tras cambios, incidentes y nueva evidencia.
- Mantener riesgo residual dentro de criterios aceptables.
- Conservar trazabilidad de decisiones y medidas.

Gobernanza de datos

- Definir origen, permisos, calidad y representatividad.
- Analizar errores, sesgos y lagunas relevantes.
- Documentar preparación, limpieza y transformaciones.
- Evitar que datos sensibles se utilicen sin base y garantías.
- Monitorizar deriva y cambios en la población objetivo.

Documentación técnica

- Descripción general, propósito previsto y arquitectura.
- Diseño, desarrollo, validación y pruebas.
- Datos, métricas, limitaciones y riesgos conocidos.
- Medidas de supervisión y mantenimiento.
- Versiones, cambios y decisiones de conformidad.
- Debe permitir evaluar el cumplimiento, no ser solo documentación comercial.

Registros y trazabilidad

- Registrar eventos relevantes durante el funcionamiento.
- Permitir reconstruir incidentes y decisiones cuando sea viable.
- Definir acceso, integridad, conservación y minimización.
- Sincronizar identificadores de versión, modelo y conjunto de datos.
- Alinear registros con RGPD y políticas de seguridad.

Transparencia e instrucciones

- Informar a los responsables del despliegue sobre capacidades y límites.
- Explicar propósito previsto y condiciones de uso.
- Detallar supervisión humana y mantenimiento.
- Comunicar precisión, robustez y ciberseguridad según corresponda.
- La información debe ser útil para operar de forma segura.

Supervisión humana

- Diseñar la supervisión desde el inicio.
- Permitir interpretar resultados y detectar anomalías.
- Facilitar ignorar, revertir o detener resultados cuando proceda.
- Ajustar la supervisión al riesgo y a la autonomía.
- Evitar que el humano sea una aprobación automática sin capacidad real.

Precisión, robustez y ciberseguridad

- Definir métricas relevantes para el uso previsto.
- Probar bajo condiciones normales y razonablemente previsibles.
- Evaluar fallos, ataques, manipulación de entradas y extracción de datos.
- Gestionar vulnerabilidades y actualizaciones.
- Documentar límites, umbrales y procedimientos de respuesta.

Obligaciones del responsable del despliegue

- Usar el sistema conforme a instrucciones y finalidad prevista.
- Asignar supervisión humana competente cuando proceda.
- Controlar datos de entrada bajo su responsabilidad.
- Monitorizar funcionamiento e informar de riesgos o incidentes.
- Conservar registros bajo su control y respetar obligaciones laborales y de datos.

Evaluación de impacto en derechos fundamentales

- Puede ser obligatoria para ciertos responsables y usos de alto riesgo.
- Analiza procesos, personas afectadas, riesgos y medidas.
- Considera grupos vulnerables y consecuencias discriminatorias.
- Define gobernanza, supervisión y mecanismos de reclamación.
- Coordinarla con la evaluación de impacto de protección de datos cuando proceda.

Evaluación de conformidad

- Demuestra que el sistema cumple requisitos aplicables.
- El procedimiento depende de la categoría y del marco sectorial.
- Puede implicar control interno o intervención de organismo notificado.
- La documentación debe ser coherente con la versión evaluada.
- Cambios sustanciales pueden requerir nueva evaluación.

Marcado, declaración y registro

- Aplican según el sistema y el procedimiento pertinente.
- La declaración UE de conformidad expresa responsabilidad del proveedor.
- El marcado CE no es un sello genérico de calidad ética.
- Algunos sistemas deben registrarse en bases de datos de la UE.
- Verificar los artículos y anexos aplicables a cada caso.

Incidentes y acciones correctivas

- Establecer canales para detectar y clasificar incidentes.
- Evaluar si se trata de un incidente grave conforme a la norma.
- Notificar a las autoridades en los plazos y condiciones aplicables.
- Aplicar medidas correctivas, retirada o recuperación cuando proceda.
- Preservar evidencias y realizar análisis de causa raíz.

Modelos de IA de uso general

- El Reglamento incorpora obligaciones específicas para proveedores de modelos GPAI.
- Documentación técnica e información para integradores.
- Política de cumplimiento de derechos de autor en los supuestos previstos.
- Resumen del contenido usado para entrenamiento según requisitos aplicables.
- Los modelos con riesgo sistémico tienen obligaciones reforzadas.

Riesgo sistémico en GPAI

- Evaluar capacidades y riesgos sistémicos según criterios legales.
- Realizar pruebas y evaluaciones de modelos.
- Valorar y mitigar riesgos sistémicos a escala de la UE.
- Notificar incidentes graves y mantener ciberseguridad adecuada.
- Las obligaciones concretas dependen de la clasificación y versión vigente.

Transparencia en IA generativa

- Identificar contenido sintético en los casos exigidos.
- Marcar deepfakes y ciertos textos de interés público cuando proceda.
- Informar a personas cuando interactúan directamente con IA, salvo excepciones.
- La forma técnica de marcado debe ser eficaz y compatible con el uso.
- No confundir transparencia del AI Act con base jurídica RGPD.

Alfabetización en IA

- Proveedores y responsables del despliegue deben adoptar medidas para un nivel suficiente.
- Considerar conocimientos, experiencia, formación y contexto de uso.
- Formar a equipos técnicos, usuarios y responsables de decisión.
- Documentar contenidos, fechas, roles y evaluación de aprendizaje.
- La alfabetización es continua, no una sesión aislada.

Innovación y sandboxes

- Los sandboxes regulatorios facilitan pruebas controladas.
- Deben existir objetivos, límites, supervisión y salvaguardas.
- No equivalen a una exención general de la legislación.
- Pueden apoyar a pymes y organizaciones innovadoras.
- Comprobar mecanismos nacionales y condiciones vigentes.

Gobernanza europea y nacional

- La Comisión y la Oficina de IA desempeñan funciones a nivel de la UE.
- El Comité Europeo de IA facilita coordinación.
- Las autoridades nacionales ejercen funciones de vigilancia y aplicación.
- Los organismos notificados participan cuando el procedimiento lo requiere.
- La arquitectura institucional puede evolucionar con las modificaciones normativas.

Sanciones y cumplimiento

- Las sanciones varían según infracción y tipo de operador.
- El Reglamento establece límites basados en importes y/o volumen de negocio.
- Pueden existir medidas correctivas y restricciones de mercado.
- La proporcionalidad y las reglas específicas para pymes deben revisarse.
- Un programa de cumplimiento reduce riesgo, pero no garantiza ausencia de sanciones.

Calendario de aplicación: visión general

- Entrada en vigor del AI Act: 1 de agosto de 2024.
- La aplicación se despliega por fases.
- Las prohibiciones y alfabetización tienen fechas tempranas.
- Las obligaciones de alto riesgo tienen calendarios y transiciones específicos.
- El Ómnibus 2026 modifica fechas y condiciones de ciertas obligaciones.
- Usar calendario consolidado actualizado, no diapositivas antiguas.

REGLAMENTO (UE) 2026

**Ómnibus digital
sobre IA**

Resumen de la norma

Idea central

El Reglamento (UE) 2026/1744 modifica el marco europeo de IA para facilitar su aplicación y adaptar determinados calendarios, procedimientos y obligaciones. Debe interpretarse conjuntamente con el AI Act: no constituye un marco independiente que lo sustituya. Para cada sistema es necesario comprobar la redacción modificada, las disposiciones transitorias y la fecha concreta de aplicación.

- **Naturaleza:** Reglamento de la Unión Europea.
- **Enfoque:** gobernanza, riesgos, impactos y cumplimiento según el marco aplicable.
- **Aplicación:** analizar siempre alcance, contexto, responsables y fecha de aplicación.

Ómnibus digital sobre IA: finalidad

- Reglamento (UE) 2026/1744, adoptado el 8 de julio de 2026.
- Modifica el AI Act y otros actos citados en su título.
- Busca simplificar la implementación de reglas armonizadas de IA.
- Responde, entre otros factores, a retrasos en normas y marcos de evaluación.
- Debe leerse como modificación del texto base, no como sustituto integral.

Ómnibus 2026: cómo leerlo

- Identificar artículos modificados y nueva redacción.
- Comprobar disposiciones transitorias y fechas de aplicación.
- Distinguir cambios sustantivos, aclaraciones y simplificaciones.
- Actualizar procedimientos, inventario de sistemas y cronograma.
- Consultar texto publicado en DOUE y versión consolidada de EUR-Lex.

Ómnibus 2026: fechas de alto riesgo

- La Comisión indica aplicación desde el 2 de diciembre de 2027 para ciertas áreas de alto riesgo del anexo III.
- Para sistemas integrados en productos regulados se indica el 2 de agosto de 2028.
- Las fechas dependen de la categoría y de las condiciones legales.
- No extrapolar una fecha única a todos los sistemas.
- Verificar disposiciones transitorias del Reglamento 2026/1744.

Ómnibus 2026: impacto práctico

- Actualizar matriz de obligaciones y responsables.
- Revisar hitos de evaluación de conformidad y disponibilidad de estándares.
- Replanificar recursos sin reducir controles necesarios de seguridad.
- Mantener evidencias de cumplimiento durante el periodo transitorio.
- Validar cada cambio frente al artículo modificado.

REGLAMENTO (UE) 2016

**Reglamento
General de
Protección de
Datos — RGPD**

Resumen de la norma

Idea central

El RGPD regula el tratamiento de datos personales y protege los derechos y libertades de las personas. En sistemas de IA resulta especialmente relevante cuando se utilizan datos personales para entrenamiento, validación, inferencia o monitorización. Sus principios de licitud, minimización, transparencia, seguridad y responsabilidad proactiva deben coordinarse con las obligaciones específicas del AI Act.

- **Naturaleza:** Reglamento de la Unión Europea.
- **Enfoque:** gobernanza, riesgos, impactos y cumplimiento según el marco aplicable.
- **Aplicación:** analizar siempre alcance, contexto, responsables y fecha de aplicación.

AI Act y RGPD: relación

- Se aplican de forma complementaria cuando existe tratamiento de datos personales.
- El AI Act no reemplaza principios, bases jurídicas ni derechos del RGPD.
- El RGPD no reemplaza requisitos técnicos y organizativos del AI Act.
- Una misma actividad puede exigir análisis separados pero coordinados.
- Documentar la interacción entre obligaciones.

Principios del RGPD

- Licitud, lealtad y transparencia.
- Limitación de la finalidad y minimización.
- Exactitud y limitación del plazo de conservación.
- Integridad, confidencialidad y responsabilidad proactiva.
- Protección de datos desde el diseño y por defecto.

Base jurídica y finalidad

- Identificar finalidad concreta y compatible.
- Determinar base jurídica del artículo 6.
- Si hay categorías especiales, analizar artículo 9.
- No asumir que el interés legítimo siempre es válido para entrenar IA.
- Informar a las personas de manera clara y verificable.

Derechos de las personas

- Acceso, rectificación, supresión y limitación cuando proceda.
- Portabilidad y oposición en sus condiciones legales.
- Garantías frente a decisiones individuales automatizadas: artículo 22.
- Facilitar canales para ejercer derechos y responder en plazo.
- Las excepciones deben interpretarse y documentarse.

Evaluación de impacto en protección de datos

- La EIPD es obligatoria cuando el tratamiento probablemente entrañe alto riesgo.
- Describir operaciones, finalidades y necesidad/proporcionalidad.
- Evaluar riesgos para derechos y libertades.
- Definir medidas para abordar riesgos.
- Consultar a la autoridad cuando persista alto riesgo en los supuestos previstos.

Datos de entrenamiento y RGPD

- Determinar roles de responsable y encargado.
- Documentar origen, base jurídica y retención de datos.
- Evaluar minimización, exactitud y derechos de los interesados.
- Valorar anonimización real frente a seudonimización.
- Considerar transferencias internacionales y contratos con proveedores.

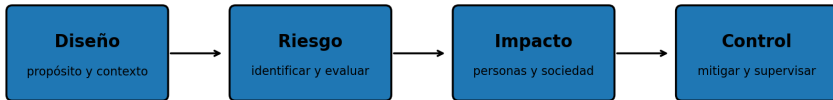
Decisiones automatizadas y perfilado

- Distinguir apoyo a decisiones de decisiones exclusivamente automatizadas.
- Examinar efectos jurídicos o significativamente similares.
- Aplicar garantías y excepciones del artículo 22 cuando corresponda.
- Ofrecer intervención humana, posibilidad de expresar punto de vista e impugnar, cuando proceda.
- La transparencia no convierte por sí sola una decisión en lícita.

ISO/IEC 42001:2023

**Sistema de
Gestión de
Inteligencia
Artificial**

Ciclo de gobernanza de un sistema de IA



Resumen de la norma

Idea central

ISO/IEC 42001:2023 establece requisitos para implantar, mantener y mejorar un sistema de gestión de inteligencia artificial. Su objetivo es proporcionar una estructura organizativa para gobernar la IA mediante políticas, responsabilidades, gestión de riesgos, controles, evaluación del desempeño y mejora continua. Es una norma de gestión y no sustituye las obligaciones legales europeas.

- **Naturaleza:** Norma internacional ISO/IEC.
- **Enfoque:** gobernanza, riesgos, impactos y cumplimiento según el marco aplicable.
- **Aplicación:** analizar siempre alcance, contexto, responsables y fecha de aplicación.

ISO/IEC 42001:2023: propósito

- Norma de requisitos para un sistema de gestión de IA (AIMS/SGIA).
- Aplicable a organizaciones que desarrollan, proporcionan o utilizan IA.
- Enfoque organizativo, transversal y de mejora continua.
- Integra políticas, responsabilidades, procesos, evaluación y seguimiento.
- Puede servir como marco de gobernanza; no sustituye el AI Act.

ISO/IEC 42001: estructura de gestión

- Contexto y partes interesadas.
- Liderazgo, política y responsabilidades.
- Planificación de riesgos y oportunidades.
- Soporte, competencias, comunicación y documentación.
- Operación, evaluación del desempeño y mejora.
- Aplicar el ciclo Planificar-Hacer-Verificar-Actuar.

ISO 42001: controles y evidencias

- Política y objetivos de IA aprobados.
- Inventario de sistemas, roles y ciclo de vida.
- Evaluaciones de riesgos e impactos.
- Controles de datos, proveedores, desarrollo y operación.
- Auditorías internas, revisión de dirección y acciones correctivas.
- Evidencias proporcionales al contexto y alcance del SGIA.

ISO/IEC 23894:2023

**Gestión de
riesgos de
inteligencia
artificial**

Resumen de la norma

Idea central

ISO/IEC 23894:2023 proporciona orientación para gestionar los riesgos específicos asociados a sistemas de inteligencia artificial. Propone integrar la identificación, análisis, evaluación, tratamiento, comunicación y monitorización de riesgos durante el ciclo de vida. Complementa la gobernanza organizativa de ISO/IEC 42001 y puede ayudar a estructurar la gestión de riesgos exigida por otros marcos.

- **Naturaleza:** Norma internacional ISO/IEC.
- **Enfoque:** gobernanza, riesgos, impactos y cumplimiento según el marco aplicable.
- **Aplicación:** analizar siempre alcance, contexto, responsables y fecha de aplicación.

ISO/IEC 23894:2023: propósito

- Guía para gestionar riesgos relacionados con IA.
- Integra el riesgo de IA en la gestión global de la organización.
- Considera incertidumbre, datos, modelos, interacción humana y contexto.
- Apoya la identificación, análisis, evaluación y tratamiento de riesgos.
- Es guía técnica, no un reglamento de certificación por sí misma.

ISO 23894: proceso de riesgos

- Establecer contexto, criterios y apetito de riesgo.
- Identificar escenarios de daño y fuentes de incertidumbre.
- Analizar probabilidad, impacto y exposición.
- Evaluar prioridad y decidir tratamiento.
- Registrar riesgo residual, propietario y aceptación.
- Comunicar, monitorizar y revisar durante todo el ciclo de vida.

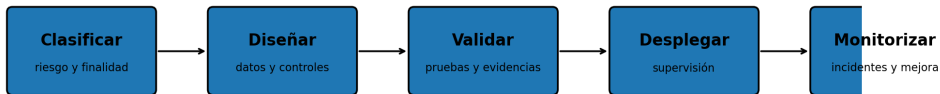
Riesgos específicos de IA

- Sesgo y discriminación.
- Errores, alucinaciones y baja robustez.
- Falta de explicabilidad o supervisión efectiva.
- Privacidad, seguridad y fuga de datos.
- Deriva del modelo, cambios de distribución y degradación.
- Dependencia de proveedores, uso indebido y efectos sociales.

ISO/IEC 42005:2025

**Evaluación del
impacto de los
sistemas de IA**

Ciclo de vida y cumplimiento



Resumen de la norma

Idea central

ISO/IEC 42005:2025 proporciona orientación para evaluar los impactos de los sistemas de IA sobre personas, grupos y sociedad. La evaluación considera el contexto, las partes interesadas, los beneficios, los posibles daños y las medidas de mitigación a lo largo del ciclo de vida. Es especialmente útil para complementar la gestión de riesgos y las evaluaciones regulatorias de impacto.

- **Naturaleza:** Norma internacional ISO/IEC.
- **Enfoque:** gobernanza, riesgos, impactos y cumplimiento según el marco aplicable.
- **Aplicación:** analizar siempre alcance, contexto, responsables y fecha de aplicación.

ISO/IEC 42005:2025: evaluación de impacto

- Guía para evaluar impactos de sistemas de IA.
- Considera personas, grupos y sociedad.
- Incluye aplicaciones previsibles y efectos durante el ciclo de vida.
- Apoya transparencia, rendición de cuentas y confianza.
- Complementa la gestión de riesgos y los sistemas de gestión.

ISO 42005: pasos de evaluación

- Definir sistema, propósito, contexto y alcance.
- Identificar partes interesadas y grupos afectados.
- Describir beneficios, daños y escenarios previsibles.
- Evaluar gravedad, probabilidad y distribución del impacto.
- Definir medidas, responsables, seguimiento y comunicación.
- Actualizar la evaluación ante cambios o nueva evidencia.

INTEGRACIÓN DEL MARCO

**AI Act + RGPD +
ISO/IEC**

Comparativa de marcos

- **AI Act:** ¿qué obligaciones legales de IA se aplican al sistema?
- **RGPD:** ¿se tratan datos personales y qué derechos y garantías existen?
- **ISO/IEC 42001:** ¿cómo organiza la organización la gobernanza de IA?
- **ISO/IEC 23894:** ¿cómo se identifican y tratan los riesgos?
- **ISO/IEC 42005:** ¿qué impactos produce o puede producir el sistema?

Caso práctico: IA de selección de personal

- Clasificar el uso y comprobar el régimen de alto riesgo.
- Evaluar sesgos, validez, datos y criterios de selección.
- Coordinar AI Act, RGPD y normativa laboral.
- Definir supervisión humana y mecanismos de reclamación.
- Documentar pruebas, limitaciones, versiones y monitorización.

Checklist de cumplimiento

- Inventario y propietario del sistema.
- Clasificación AI Act y justificación.
- Evaluaciones de riesgo e impacto.
- Datos, privacidad y base jurídica.
- Pruebas de rendimiento, robustez y seguridad.
- Transparencia, supervisión humana y formación.
- Registros, incidentes, auditoría y mejora continua.

Resumen ejecutivo

- Clasificar primero; aplicar las obligaciones después.
- Integrar cumplimiento jurídico, gestión de riesgos y evaluación de impacto.
- Cubrir todo el ciclo de vida del sistema.
- Mantener separado pero coordinado el cumplimiento del RGPD.
- Utilizar ISO/IEC como estructura de gobernanza y evidencias.
- Revisar continuamente las modificaciones legislativas y fechas de aplicación.

Fuentes oficiales

- Reglamento (UE) 2024/1689 — AI Act:
<https://eur-lex.europa.eu/eli/reg/2024/1689/oj/esp>
- Reglamento (UE) 2026/1744 — Ómnibus digital sobre IA:
<https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX:32026R1744>
- Comisión Europea — Marco regulador de IA: <https://digital-strategy.ec.europa.eu/es/policies/regulatory-framework-ai>
- ISO/IEC 42001:2023: <https://www.iso.org/es/norma/42001>
- ISO/IEC 23894:2023: <https://www.iso.org/standard/77304.html>
- ISO/IEC 42005:2025: <https://www.iso.org/standard/42005>
- RGPD (UE) 2016/679:
<https://eur-lex.europa.eu/legal-content/ES/ALL/?uri=celex:32016R0679>